

INTERNAL AUDIT REPORT

AI-Powered ERP Anomaly Detection &

Procurement Fraud Risk Assessment

SAP Procure-to-Pay Transaction Analysis

Fiscal Years 2022 – 2023

CONFIDENTIAL — INTERNAL USE ONLY

Prepared by:	Internal Audit & Analytics Function
Engagement type:	Continuous Controls Monitoring — AI-Augmented
Period covered:	01 January 2022 – 31 December 2023
Transactions reviewed:	13,658
Report date:	July 2026
Classification:	Confidential

1. Executive Summary

Internal Audit engaged the Analytics function to conduct an AI-powered review of the organisation's Procure-to-Pay (P2P) transaction data extracted from the SAP ERP environment. The engagement applied a multi-layer detection framework combining rule-based controls monitoring — replicating SAP GRC Process Control logic — with unsupervised machine learning models to identify procurement fraud indicators, financial control failures, and policy violations across the full population of 13,658 invoice transactions processed during fiscal years 2022 and 2023.

13,658	790	49.4 Cr	5.8%	98.3%
Transactions Analysed	Anomalies Detected	Financial Exposure at Risk	Anomaly Detection Rate	Audit Workload Reduction

Top-Line Findings

The review identified **790 transactions** exhibiting one or more indicators of financial irregularity, representing a detection rate of **5.8%** of the total transaction population. Combined financial exposure across Critical and High risk tiers amounts to **■49.35 crore (■493.5 million)**. The AI-augmented detection framework reduced manual audit review workload by **98.3%** by auto-clearing 13,427 low-risk transactions, enabling auditors to focus investigative effort on 231 priority cases.

Three-Way Match controls are operating at a **98% pass rate**, above the industry benchmark of 95%, indicating that the automated matching control in SAP is largely effective. However, **200 invoices with match failures** were identified representing deliberate or systemic deviation beyond the configured tolerance threshold. Additionally, **50 ghost vendor invoices** from vendors created and utilised within a 22-day window were detected, representing the highest per-transaction financial exposure in this review.

Three Key Recommendations

- 1. Immediate payment hold on all Critical and High tier transactions:** One Critical and 230 High tier transactions totalling **■49.35 crore** require immediate payment suspension pending investigation. Ghost vendor and three-way match failure cases carry the highest per-transaction value and should be prioritised.
- 2. Implement automated ghost vendor detection in SAP GRC:** The current vendor master creation workflow lacks automated controls to flag vendors transacting within 30 days of creation. SAP GRC Access Control should be configured to enforce a mandatory review period for all new vendors before their first invoice can be processed.
- 3. Mandate Purchase Orders for all procurement activity:** 150 invoices (1.1% of total) were processed with no corresponding Purchase Order, bypassing price negotiation, approval workflows, and three-way match controls. A hard system block on PO-less invoice posting should be implemented in SAP MM configuration.

2. Methodology

2.1 Data Sources and Coverage

Transaction data was extracted from the SAP Procure-to-Pay process spanning six core data entities: Purchase Orders (EKKO/EKPO), Goods Receipts (MSEG/MKPF), Vendor Invoices (RBKP/RSEG), Vendor Master (LFA1/LFB1), Cost Centre Budgets (BPGE/BPJA), and User Master (USR02/AGR_USERS). The dataset covers fiscal years 2022 and 2023, encompassing 13,658 invoice records, 20,150 purchase orders, 12,868 goods receipts, and 315 vendor master records across 20 cost centres.

2.2 Detection Framework

The detection framework operates in three layers applied sequentially:

Layer	Approach	Rules / Models	Purpose
1 — Rule Engine	Deterministic	9 control rules	Detect known, named violations
2 — ML Models	Unsupervised	Isolation Forest + Autoencoder	Detect statistical anomalies
3 — Risk Scoring	Composite	Weighted ensemble (40/35/25)	Prioritise by ML score, rule severity, and value

2.3 Rule-Based Detection

Rule	Control Tested	Threshold
Exact Duplicate Invoice	Same vendor, same amount, same ref within 30 days	Exact match
Near-Duplicate Invoice	Same vendor, amount within 2%, within 30 days	2% tolerance
Split Purchase Order	Multiple POs below threshold summing above it	■1,00,000
Three-Way Match Failure	Invoice vs PO deviation outside tolerance	±5%
Maverick Buying	Invoice with no corresponding Purchase Order	Any
After-Hours Transaction	Posting outside 08:00–19:00 or on weekends	Business hours
Budget Overrun	Actual spend exceeds approved cost centre budget	100%
Round Number Invoice	Amount divisible by ■1,000 or higher modulo	Statistical
New Vendor Fast Payment	Vendor created within 7 days of first invoice	7 days

2.4 Machine Learning Models

Isolation Forest (scikit-learn, 200 estimators, contamination=0.05): An unsupervised tree-based ensemble that isolates anomalies by randomly partitioning the feature space. Anomalies require fewer splits to isolate and receive lower anomaly scores. Applied to 10 engineered features including amount z-score, invoice-to-PO ratio, vendor age at transaction date, after-hours indicator, and Benford's Law first-digit deviation.

Autoencoder (Keras/TensorFlow, architecture: 10→16→8→3→8→16→10): A neural network trained exclusively on normal transactions to learn the compression-reconstruction pattern of legitimate P2P activity. Anomalous transactions produce high reconstruction error because the model has not learned their pattern. Threshold set at the 95th percentile of normal transaction reconstruction error.

Ensemble: Isolation Forest (55%) and Autoencoder (45%) scores were min-max normalised and combined into a single ensemble anomaly score. The composite 0-100 risk score weights the ensemble score (40%), rule-based severity (35%), and log-scaled transaction value (25%).

2.5 Limitations and Assumptions

- Analysis is based on transaction data only. Physical inspection of goods, vendor site visits, and bank account verification were outside scope.
- Ghost vendor detection relies on temporal proximity signals; shell companies with longer setup periods may not be captured by the 7-day threshold.
- Unsupervised ML models flag statistical outliers — not all flagged transactions will represent actual fraud. Human investigation is required to confirm findings.
- Budget overrun analysis is limited to cost-centre level; sub-account and project-level budget violations are outside scope.

3. Detailed Findings

F-01 — Three-Way Match Failures

Transactions Flagged	Financial Exposure	Risk Rating
200	■ 119.2M	Critical

Finding Description

Three-way match validation compares the invoice amount against the originating Purchase Order and Goods Receipt within a $\pm 5\%$ tolerance. The review identified 200 invoices where the invoice amount deviated beyond this threshold, with deviations ranging from -34.7% to +34.9% of PO value. SAP correctly blocked these invoices for payment, however the volume of failures indicates a systemic issue requiring root cause investigation.

Business Impact

Invoices above PO value represent potential vendor overbilling. Invoices significantly below PO value may indicate partial delivery being billed at full value, or price manipulation to remain close to the approval tolerance boundary.

Root Cause Hypothesis

Most probable causes: (1) vendor invoicing at incorrect contracted rate, (2) quantity discrepancy between delivery and invoice, (3) deliberate amount manipulation to stay below investigation thresholds. The concentration of deviations between 5-15% suggests pattern (3) in a subset of cases.

Recommended Action

AP Manager to review and clear each blocked invoice individually with written vendor explanation. Cases with deviation >15% to be escalated to Internal Audit for full investigation. Implement SAP workflow routing for match failures above 10% deviation directly to the Finance Manager rather than AP Clerk level.

F-02 — Ghost Vendor Invoices

Transactions Flagged	Financial Exposure	Risk Rating
50	■ 53.8M	Critical

Finding Description

50 invoices were identified from 15 vendors created within 3-22 days of their first invoice submission. These vendors exhibit multiple ghost vendor indicators: non-corporate contact email addresses, residential-pattern registered addresses, and payment terms of 15 days (significantly shorter than the standard 30-90 day terms). All ghost vendor invoices were paid, with no corresponding Purchase Order or Goods Receipt.

Business Impact

Ghost vendor fraud represents the highest per-transaction financial exposure in this engagement. Payments made to fraudulent vendors result in direct financial loss with no goods or services received.

Root Cause Hypothesis

The vendor master creation workflow does not enforce a mandatory cooling-off period before a new vendor can receive payment. Additionally, Segregation of Duties analysis indicates that in several instances, the user who created the vendor record also had access to the invoice approval workflow — a critical SoD violation.

Recommended Action

Immediately freeze all 15 identified ghost vendors in the SAP vendor master (transaction MK06). Initiate bank account verification for all 15 vendors via independent channel. Implement a mandatory 30-day new vendor review period in SAP GRC Access Control before invoice processing is permitted. Investigate SoD violations for users with combined vendor creation and payment approval access.

F-03 — Maverick Buying — Invoices Without Purchase Orders

Transactions Flagged	Financial Exposure	Risk Rating
150	■90.2M	High

Finding Description

150 invoices (1.1% of total) were processed and paid without a corresponding Purchase Order reference. These transactions completely bypassed the procurement control framework — no vendor selection process, no price negotiation, no approval workflow, and no three-way match capability.

Business Impact

Maverick buying exposes the organisation to overpayment risk, prevents leverage in vendor negotiations, and creates audit trail gaps. Industry benchmarks suggest maverick buying rates above 10% indicate a procurement compliance culture issue requiring policy intervention, not just individual transaction remediation.

Root Cause Hypothesis

SAP MM is not configured with a hard block on PO-less invoice posting. AP Clerks have the system access to post invoices without a PO reference, and the current AP Manager approval workflow does not flag or escalate PO-less invoices differently from matched ones.

Recommended Action

Configure SAP MM to require a valid PO reference for all invoices above ■10,000. Implement a separate AP workflow queue for PO-less invoices requiring Finance Manager sign-off and business justification. Issue procurement policy reminder to all department heads with mandatory PO-first training for budget holders.

F-04 — Duplicate and Near-Duplicate Invoices

Transactions Flagged	Financial Exposure	Risk Rating
200	■127.5M	High

Finding Description

The review identified 120 exact duplicate invoices and 80 near-duplicate invoices (same vendor, amount differing by 0.5-2%, within 30 days). Exact duplicates share the same vendor invoice reference number — a primary indicator of inadvertent re-submission or deliberate double-billing. Near-duplicates with slightly altered

amounts suggest sophisticated evasion of standard exact-match duplicate detection controls.

Business Impact

Each duplicate invoice pair represents a potential double-payment to the vendor. Near-duplicate patterns, particularly where the amount difference is consistently less than 2%, warrant investigation for deliberate manipulation.

Root Cause Hypothesis

SAP's standard duplicate invoice check (transaction MIRO) is configured for exact matching on vendor, amount, and reference number. Near-duplicate patterns with slightly altered amounts or reference numbers evade this check. Manual AP Clerk review is the only current control for near-duplicates — insufficient at current transaction volumes.

Recommended Action

Implement fuzzy matching logic in the AP invoice processing workflow to flag invoices within 5% of a recent same-vendor invoice for manual review. All 120 exact duplicates should be confirmed with vendors that only one payment is due. Recovery procedures should be initiated for any duplicates already paid.

F-05 — After-Hours Transaction Postings

Transactions Flagged	Financial Exposure	Risk Rating
100	■ 57.2M	Medium

Finding Description

100 invoice postings were recorded outside normal business hours (08:00–19:00 Monday to Friday). Legitimate AP operations are conducted by office-based staff during business hours. After-hours postings may indicate unauthorised system access, credential sharing, or deliberate timing of fraudulent transactions to reduce oversight probability.

Business Impact

While not all after-hours postings represent fraud, the combination of after-hours timing with other risk factors (high value, new vendor, no PO) significantly elevates the risk profile of individual transactions.

Root Cause Hypothesis

SAP does not have time-based access restrictions configured for AP Clerk and AP Manager roles. Users retain full transaction access 24 hours a day, seven days a week.

Recommended Action

Implement SAP logon time restrictions for AP roles via transaction SU01 / SU10, limiting system access to 07:00–21:00 on business days. After-hours access should require explicit Finance Manager authorisation via a temporary elevated access request. All 100 after-hours transactions should be reviewed for business justification.

F-06 — Budget Overruns

Transactions Flagged	Financial Exposure	Risk Rating

7

■ 5.9M

Medium

Finding Description

7 cost centres recorded actual expenditure exceeding their approved annual budget, with utilisation rates ranging from 100.1% to 125.7%. SAP CO was not configured with hard budget checks (availability control) for these cost centres, allowing transactions to post beyond the approved limit without system intervention.

Business Impact

Budget overruns indicate either inadequate budget planning, unauthorised expenditure, or deliberate circumvention of financial controls. Overruns that are not identified and approved in-period create cash flow risk and reporting inaccuracies.

Root Cause Hypothesis

SAP CO availability control is configured in 'Warning' mode rather than 'Error' mode for the affected cost centres, allowing postings to proceed beyond budget with only a system warning that users can override.

Recommended Action

Switch SAP CO availability control to 'Error' mode for all cost centres above ■50 lakh annual budget. Implement a supplementary budget approval workflow requiring CFO sign-off before overrun postings are permitted. Obtain retrospective CFO approval for all 7 identified overruns.

4. Overall Procurement Control Environment Risk Rating

HIGH RISK

The organisation's procurement control environment is rated **HIGH RISK** based on the following assessment criteria:

Risk Domain	Assessment	Rating
Three-Way Match Controls	Operating at 98% pass rate — above benchmark. Failure volume requires investigation.	Medium
Ghost Vendor / Vendor Master	Critical SoD violations detected. Immediate remediation required.	Critical
Procurement Compliance	1.1% maverick buying rate — systemic policy failure.	High
Duplicate Payment Controls	Near-duplicate evasion pattern detected — current controls inadequate.	High
Access & Timing Controls	100 after-hours postings — no time-based access restrictions in place.	Medium
Budget Management	7 cost centres over budget — availability control in Warning mode only.	Medium

5. Management Action Plan

The following remediation actions are presented in priority order. Management is requested to confirm acceptance of findings and assign named owners for each action within 10 business days of report receipt.

#	Action	Owner	Timeline	Priority
1	Freeze all 15 ghost vendors in SAP vendor master (MK06). Initiate independent bank account verification.	AP Manager	Immediate (1-3 days)	Critical
2	Place payment hold on all Critical and High tier invoices (231 transactions, █49.4 Cr).	Finance Manager	Immediate (1-3 days)	Critical
3	Investigate SoD violations — users with combined vendor creation and payment approval access.	Internal Audit	5 business days	Critical
4	Configure SAP MM hard block on PO-less invoice posting above █10,000.	SAP Basis / MM	2 weeks	High
5	Implement 30-day new vendor cooling-off period in SAP GRC Access Control.	SAP GRC Admin	2 weeks	High
6	Deploy fuzzy duplicate invoice matching in AP workflow to catch near-duplicate evasion.	IT / SAP Dev	4 weeks	High
7	Switch SAP CO availability control to Error mode for all cost centres >█50L budget.	SAP CO / Finance	2 weeks	Medium
8	Implement time-based SAP logon restrictions for AP roles (07:00–21:00 business days).	SAP Basis	3 weeks	Medium
9	Obtain retrospective CFO approval for all budget overruns (7 cost centres).	CFO Office	1 week	Medium
10	Issue mandatory procurement compliance training for all budget holders and department heads.	HR / Procurement	4 weeks	Low

This report has been prepared for internal use only. Findings are based on transaction data analytics and statistical modelling; conclusions represent risk indicators requiring human investigation and should not be treated as confirmed fraud determinations. Distribution of this report is restricted to Internal Audit, the CFO, and named action owners.